

FINOVA

Risk Assessment Service

High-Level Requirements Document

Document ID	FV-HLD-RISK-002
Version	1.0
Date	March 6,2026
Classification	Confidential
Based On	Risk Engine BRD (FV-BRD-RISK-001)
Author	Tuba Khan-Technical Product Lead

CONFIDENTIAL – INTERNAL USE ONLY

Table of Contents

1. Executive Summary

- 1.1 Purpose & Scope
- 1.2 Service Overview

2. System Context & Architecture

- 2.1 Platform Ecosystem
- 2.2 Service Boundaries
- 2.3 Multi-Tenant Architecture

3. Tenant Onboarding & Configuration

- 3.1 Tenant Lifecycle
- 3.2 LOV Configuration Model
- 3.3 Linking LOVs to Risk Parameters

4. Risk Scoring Methodology (Illustrative Model)

- 4.1 Scoring Concept
- 4.2 Category & Factor Weight Model (Example)
- 4.3 Dominant Override Concept
- 4.4 Risk Level Classification
- 4.5 KYC & EDD Question Types

5. Internal Risk Engine – Processing Design

- 5.1 Assessment Session Lifecycle
- 5.2 Scoring Pipeline
- 5.3 Override & Flag Rules

6. Functional Requirements¹¹

- 6.1 Tenant Management (FR-T)
- 6.2 LOV Management (FR-L)
- 6.3 Risk Parameter Management (FR-P)
- 6.4 Scoring Engine (FR-S)
- 6.5 Answer History & Audit Trail (FR-A)
- 6.6 Third-Party AML & Sanctions Integration (FR-TP)

7. Non-Functional Requirements

8. Acceptance Criteria

9. Post-Assessment Status & Approval Workflow

1. Executive Summary

1.1 Purpose & Scope

This document defines the high-level requirements for the Risk Assessment Service within the Finova platform. It is intended for the Project Manager and Engineering Manager as the primary planning and scoping reference for the service build.

The document is derived from the Finova Risk Engine BRD (FV-BRD-RISK-001), supplemented by a reference AML Individual Risk Schema used to illustrate how category-weighted scoring works in practice. All schema values referenced are examples only — final LOV sets, weights, and thresholds are configured by each tenant through the admin interface, not hard-coded into the system.

1.2 Service Overview

Once a user has been fully onboarded through the LOS / LMS, the system initiates a risk assessment. The Risk Assessment Service handles this through two independent pillars:

- **Internal Risk Engine** — a configurable, tenant-driven scoring engine that evaluates risk across Customer, Business, and Loan dimensions. Questions, answer options (LOVs), weights, override rules, and risk thresholds are all configured per-tenant through a self-service admin interface.
- **Third-Party Assessment** — the same Risk Assessment Service also invokes external AML screening, sanctions checking, local tests, and blocklist verification by calling a third-party middleware service. The results are received and returned as part of the unified risk assessment response. There is no separate consumer-facing service for this; it is handled internally within the Risk Assessment Service.

SCOPE OF THIS DOCUMENT

This document covers the full Risk Assessment Service — both the Internal Risk Engine and the third-party AML / sanctions checks invoked via middleware.

The Risk Assessment Service is the single service that orchestrates both pillars and returns a unified result to LOS/LMS.

All LOV values, weights, and thresholds cited as examples are ILLUSTRATIVE only.

Real values will be configured by tenants through the self-service admin portal.

2. System Context & Architecture

2.1 Platform Ecosystem

Finova is a financial platform through which customers and businesses are onboarded and loan products are originated and managed. The LOS / LMS serves as the core platform and is the primary consumer of the Risk Assessment Service.

LOS / LMS	Core loan origination and management platform. Handles customer and business onboarding, application processing, and product configuration. Triggers risk assessment via API after onboarding completes.
Risk Assessment Service	The subject of this document. An independent microservice that receives an onboarded entity reference from LOS/LMS, runs the Internal Risk Engine, invokes third-party AML and sanctions checks via middleware, and returns a unified risk result.
Third-Party ,International & Local Listing	External middleware layer called internally by the Risk Assessment Service. Handles AML screening, sanctions list checks, local regulatory tests, and blocklist verification. Results are received by the Risk Assessment Service and included in the response to LOS/LMS.

2.2 Service Boundaries

The Risk Assessment Service is designed as a fully autonomous component that orchestrates both the internal scoring engine and the third-party AML checks. It owns its configuration and data, and exposes a defined API surface to LOS/LMS.

- Inbound: LOS/LMS sends an onboarded entity details and risk type context (Customer / Business / Loan) to the Risk Assessment Service via internal API after onboarding completes.
- Outbound: The service returns a unified risk result containing: the computed internal risk score, the resulting risk level (Low / Medium / High / PEP), the PEP flag, and the results received from third-party AML and sanctions checks — all in a single response to LOS/LMS.
- Third-party calls: The Risk Assessment Service calls the third-party AML middleware internally as part of its assessment pipeline. LOS/LMS does not call the third-party service directly.
- Isolated database: The Risk Assessment Service maintains its own database. It has no read or write access to the LOS/LMS database. All data exchange is via API contract only.

- Independent deployability: The service deploys, scales, and updates independently from LOS/LMS without causing downtime or configuration changes on either side.

2.3 Multi-Tenant Architecture

The Internal Risk Engine is a tenant-based system. Each tenant is onboarded independently and operates within a fully isolated configuration space. One tenant's configuration, data, and assessment results have zero visibility into or impact on any other tenant.

- All data is scoped by tenant_id at every layer of the service.
- Each tenant independently defines its own LOV sets, risk parameters, scoring thresholds, and override rules.
- Each tenant authenticates with its own API credentials.
- No shared state exists between tenants at the service, application, or database level.

3. Tenant Onboarding & Configuration

3.1 Tenant Lifecycle

Before any assessment can run, a tenant must be registered and fully configured. The sequence below defines the end-to-end onboarding process for a new tenant:

Step	Action	Actor	Outcome
1	Register Tenant	Platform Admin	Tenant record created; unique tenant_id provisioned; API credentials issued.
2	Configure Risk Types	Tenant Admin	Activate Customer, Business, and/or Loan risk dimensions for this tenant.
3	Define LOV Master Sets	Tenant Admin	Create answer-option libraries (e.g. Nationalities, Occupations, Income Bands) with factor weights and/or risk statuses per entry.
4	Create Risk Parameters	Tenant Admin	Define assessment questions per risk type, category, and sub-category. Assign category weight at the parameter level. Link parameters to LOV sets.
5	Set Scoring Thresholds	Tenant Admin	Configure score ranges that map to Low / Medium / High risk levels for each active risk type.
6	Test & Validate	Tenant Admin	Run test assessments to verify scoring logic, conditional branching, and override rules behave correctly.
7	Go Live	Platform Admin	Configuration promoted to production. Live assessments begin processing.

3.2 LOV (List of Values) Configuration Model

LOV sets are the answer-option libraries that power the scoring engine. Each LOV set groups a collection of selectable answer options for a given assessment question. Each option within a set carries a risk contribution defined through a factor weight, a direct risk status, or both.

NOTE: Category Weight

Category weight — the percentage contribution of a question category to the total score — is configured at the Risk Parameter level, not on the LOV set.

The LOV set only defines the answer options and their individual factor weights / risk statuses.

Property	Required?	Description
LOV Set Name	Yes	Logical group name identifying the answer set (e.g. 'Nationality', 'Occupation', 'Monthly Income Band').
Factor Code	Yes	Internal code identifying this answer option, used in scoring logic and audit records.
Label (EN)	Yes	English display label rendered to the user during assessment.
Label (AR)	Yes	Arabic display label for Arabic-language assessments.
Factor Weight	Optional	Numeric value 0–100 representing this option's relative risk contribution within its category. Used in the scoring formula. Required if Risk Status is not set.
Risk Status	Optional	Direct categorical label: Low / Medium / High. Acts as a classifier rather than a score contributor. Used for Dominant category types. Required if Factor Weight is not set.
Is Active	Yes	Boolean flag. Inactive entries are excluded from rendered questionnaires but historical answers referencing them are preserved.

RULE: Factor Weight vs. Risk Status

For each LOV entry, at least one of Factor Weight or Risk Status must be defined.

Factor Weight feeds the numeric scoring formula: $\text{Score} = \text{Factor Weight} \times \text{Category Weight} / 100$.

Risk Status is used for Dominant categories (e.g. PEP) where a match immediately sets the risk level regardless of the computed total score.

3.3 Linking LOVs to Risk Parameters

When a Tenant Admin defines a risk parameter (assessment question), they link it to an existing LOV set. This linkage determines:

- Which answer options are presented to the user for that question.
- How the selected answer contributes to the risk score via the factor weight stored on the LOV entry.
- Whether the answer triggers a conditional child question (linked LOV / link_lov parameter type).
- Whether a specific answer activates a compliance flag on the assessment session (PEP, EDD, or KYC).
- The category weight for this question — configured on the parameter itself, not the LOV set — defines what percentage of the total score this question category contributes.

4. Risk Scoring Methodology (Illustrative Model)

This section explains how the scoring engine works conceptually. The examples below are drawn from a reference AML Individual Risk Schema to illustrate the calculation model. These values are illustrative only — each tenant configures their own categories, factor weights, and thresholds through the admin portal.

4.1 Scoring Concept

The engine uses a weighted LOV scoring model. Risk is evaluated across multiple categories (e.g. Nationality, Occupation, Income Range). Each category carries a category weight — its percentage contribution to the total possible score — which is set on the corresponding risk parameter. Within a category, each answer option (LOV entry) carries a factor weight (0–100) representing the relative risk level of that specific answer.

Score formula:

Score Contribution = (Factor Weight × Category Weight) ÷ 100

The total risk score is the sum of all score contributions across answered parameters, excluding any EDD-flagged answers from the total.

4.2 Category & Factor Weight Model — Illustrative Example

The table below illustrates how categories, factor weights, and the score formula interact. These are example structures only, shown to demonstrate the calculation logic. In the live system, tenants define their own categories and values.

Category (Example)	Category Type	Cat. Weight (Example)	Example Answer Option	Factor Weight (Example)	Resulting Score Contribution
PEP	Dominant	—	PEP match = YES	—	Immediate override – risk set to PEP, no score computed
Restricted Nationality List	Dominant	—	Match on internal list = YES	—	Immediate override – risk set to High, no

Category (Example)	Category Type	Cat. Weight (Example)	Example Answer Option	Factor Weight (Example)	Resulting Score Contribution
					score computed
Nationality	Mutual Exclusive	16%	High-risk country (FATF list)	100	$100 \times 16\% = 16.0$ pts
			Mid-risk country	37–50	(example) approx. 6–8 pts
			Low-risk / home country	20–25	(example) approx. 3–4 pts
Geographical Location	Mutual Exclusive	3%	High-risk city or region	100	$100 \times 3\% = 3.0$ pts
			Medium-risk region	50–70	(example) approx. 1.5–2.1 pts
			Low-risk region	25–35	(example) approx. 0.75–1.0 pts
Occupation	Mutual Exclusive	20%	High-risk occupation	100	$100 \times 20\% = 20.0$ pts
			Medium-risk occupation	50–75	(example) approx. 10–15 pts
			Low-risk occupation	20–30	(example) approx. 4–6 pts
Income Range	Mutual Exclusive	15%	Highest income band	100	$100 \times 15\% = 15.0$ pts
			Mid income band	40–60	(example) approx. 6–9 pts
			Low income band	20	$20 \times 15\% = 3.0$ pts
Source of Income	Mutual Exclusive	10%	Higher-risk source (e.g. Real Estate)	80–100	(example) approx. 8–10 pts

Category (Example)	Category Type	Cat. Weight (Example)	Example Answer Option	Factor Weight (Example)	Resulting Score Contribution
			Lower-risk source (e.g. Salary)	15–25	(example) approx. 1.5–2.5 pts

REMINDER: Example Values Only

Category names, weights, and factor weights above are illustrative only.

In the live system, tenants define and configure all these values via the admin portal.

The formula itself — $(\text{Factor Weight} \times \text{Category Weight} / 100)$ — is the fixed engine behaviour.

4.3 Dominant Override Concept

Some categories are classified as Dominant. A positive match in a Dominant category immediately sets the risk level to the configured outcome — the weighted score computation is bypassed entirely for that assessment.

- Dominant category: a YES or match result immediately overrides all scoring and sets the risk level directly (e.g. risk = PEP, or risk = High). The engine checks Dominant categories first before executing any weighted summation.
- Mutual Exclusive category: exactly one factor within the category applies per assessment. Its weighted contribution is added to the running total score.
- EDD-flagged answers: answers that trigger EDD are excluded from the weighted score total. They are recorded on the session as informational flags for downstream compliance workflows.

4.4 Risk Level Classification

Once the total score is computed, the engine maps it to a risk level using the tenant-configured scoring thresholds. The example ranges below are illustrative — actual thresholds are set per tenant per risk type through the admin portal.

Risk Level	Example Score Range	Description
Low Risk	0 – 30 (example)	Minimal risk indicator. Standard processing and monitoring applies.

Risk Level	Example Score Range	Description
Medium Risk	31 – 41 (example)	Moderate risk. Enhanced monitoring recommended.
High Risk	42+ (example)	Significant risk. EDD is triggered. Manual compliance review required.
PEP	Override — no score	Customer is a Politically Exposed Person. Hard override. Risk level = PEP regardless of any computed score.

4.5 KYC & EDD Question Types

KYC Questions

Standard KYC questions are collected during the onboarding flow and feed into the risk scoring calculation. Their answers contribute to the weighted score. Typical KYC question types configured by tenants include:

- Source of income — LOV question; the selected answer drives the score contribution from the source-of-income category.
- Monthly income band — LOV question; the selected band drives the income range category contribution.
- Profession / occupation — Linked LOV question; the selected occupation maps to the occupation risk category.
- Company name — Text question; contextual field, score contribution depends on tenant parameter configuration.

EDD Questions

Enhanced Due Diligence questions are triggered when a customer is classified as High Risk or is identified as a PEP. EDD answers are informational — they capture additional due diligence context but are excluded from the weighted score computation. Typical EDD question types include:

- Source of wealth — Free text, mandatory. Narrative explanation of the origin of the customer's wealth.
- Wealth value band — LOV with tenant-configured brackets. Informational; not scored.
- Expanded source of income — LOV with broader options than the KYC version. Informational; not scored.

EDD vs. Scoring

EDD answers are EXCLUDED from the weighted scoring formula.

They serve as regulatory documentation and trigger downstream compliance workflows.

The EDD flag is recorded on the assessment session; EDD answers are stored in answer history.

5. Internal Risk Engine – Processing Design

5.1 Assessment Session Lifecycle

State	Description	Trigger
Initiated	Session created. Entity reference received from LOS/LMS.	API call from LOS/LMS
In Progress	Questions rendered. Answers being collected (user input or auto-fill).	System renders parameter set
Draft Saved	Partial answers saved. Assessment not yet submitted.	User saves draft
Submitted	All mandatory answers provided. Internal score computation and third-party AML checks triggered in parallel.	User or API submits
Scored	Internal weighted score computed. Risk level assigned. Overrides evaluated.	Engine computation complete
EDD Triggered	Score meets High Risk threshold or PEP override fires. EDD questions served.	Threshold breach or PEP flag
AML Checked	Third-party AML middleware called. Sanctions, local test, and blocklist results received and recorded.	Internal pipeline step
Completed	Final internal risk level and third-party AML results persisted. Unified result returned to LOS/LMS.	All steps done
Re-evaluated	A previously submitted answer was modified. Full re-evaluation executed including re-triggering third-party checks if required.	Answer change event

5.2 Scoring Engine Pipeline

The engine executes the following steps for every assessment session:

- Step 1 – Load Parameters: Retrieve all active parameters for the tenant, risk type, flow, category, sub-category, and requested language (AR / EN).
- Step 2 – Render Questions: Dynamically render the question set. Conditional child questions remain hidden until the parent answer matches the configured trigger value.
- Step 3 – Collect Answers: Capture answers of all supported types — text, boolean, LOV, linked LOV. Auto-fill parameters are populated via API trigger without user input.

- **Step 4 – Evaluate Answers:** For each answered parameter, check parent conditions, match the configured operator and expected value, and compute the weighted score contribution using the formula.
- **Step 5 – Apply Flags:** Attach PEP, EDD, and KYC flags based on answer evaluation. EDD-flagged answers are excluded from the weighted total.
- **Step 6 – Apply Dominant Overrides:** If a PEP flag is raised — by a PEP screening question or a KYC parameter match — immediately set risk level = PEP. Skip all score mapping. A match on the restricted nationality list similarly triggers a Dominant override.
- **Step 7 – Compute Final Score:** Sum all non-EDD-flagged weighted contributions. Map the total to a risk level using the tenant-configured scoring thresholds.
- **Step 8 – Aggregate Loan Risk (if applicable):** For Loan risk type, apply weighted aggregation of Customer and Business risk scores via parent_id and configurable weightage percentages.
- **Step 9 – Invoke Third-Party AML Middleware:** Call the third-party middleware service to run AML screening, sanctions list checks, local regulatory tests, and blocklist verification for the entity. This call is made internally by the Risk Assessment Service.
- **Step 10 – Receive & Record Third-Party Results:** The AML and sanctions check results are received from the middleware and stored against the assessment session. They are not merged into the internal risk score but are held as a distinct result set.
- **Step 11 – Persist & Return:** Save the final internal risk level, score, flags, and third-party results. Trigger EDD flow if applicable. Return the unified result — internal risk score, risk level, PEP flag, and third-party AML results — to LOS/LMS in a single response.

5.3 Override & Flag Rules

Flag / Override	Trigger Condition	Engine Behaviour	Score Impact
PEP Hard Override	PEP screening question = YES, or any KYC parameter matched as PEP	Risk Level set to PEP immediately. All weighted scoring bypassed.	No score computed
Dominant Nationality Override	Nationality matches the tenant's configured internal restricted list	Risk Level escalated per tenant configuration (typically High). Dominant override applied.	No score computed
EDD Trigger	Total computed score reaches or exceeds the tenant-configured High Risk threshold, or PEP override fires	EDD flag recorded on session. EDD questionnaire served to the user or operator.	EDD answers excluded from score
KYC Flag	KYC sub-category parameter evaluation matches the configured flag condition	KYC flag attached to the session. Available to downstream systems via the result payload.	No direct score impact

Flag / Override	Trigger Condition	Engine Behaviour	Score Impact
Re-evaluation	Any previously submitted answer is modified post-completion	Full re-evaluation of the entire assessment. Previous score and risk level preserved in answer history before new result is committed.	New score replaces active score

6. Functional Requirements

Requirements are derived from the Finova Risk Engine BRD (FV-BRD-RISK-001) and extended to cover the tenant management and LOV-centric scoring model described in this document.

6.1 FR-T: Tenant Management

Req ID	Requirement	Priority	MoSCoW	Notes
FR-T.1	System shall support registration of multiple tenants, each with a unique tenant_id and a fully isolated configuration and data space.	High	Must	Platform Admin only
FR-T.2	Each tenant independently configures risk types, LOV sets, risk parameters, and scoring thresholds without affecting other tenants.	High	Must	Zero cross-tenant contamination
FR-T.3	System shall support tenant-level activation and deactivation without impacting in-flight assessments or any other tenant.	High	Must	
FR-T.4	Tenant Admins shall manage all configuration through a self-service admin interface with no code deployment required.	High	Must	Self-service admin portal
FR-T.5	All tenant configuration changes shall be captured in the audit trail with actor identity, timestamp, and before/after state.	High	Must	Regulatory traceability

6.2 FR-L: LOV Management

Req ID	Requirement	Priority	MoSCoW	Notes
FR-L.1	System shall allow tenants to create and manage LOV master sets grouped by logical category (e.g. Nationality, Occupation, Income Band, Source of Income).	High	Must	
FR-L.2	Each LOV entry shall carry: Factor Code, Label EN, Label AR, Factor Weight (optional), Risk Status (optional). At least one of Factor Weight or Risk Status must be defined per entry.	High	Must	Core scoring requirement
FR-L.3	LOV entries shall support activation and deactivation without deletion, preserving all historical answer records that reference them.	High	Must	Data immutability

Req ID	Requirement	Priority	MoSCoW	Notes
FR-L.4	System shall support bulk import of LOV data from structured files (CSV / Excel) to support initial population of reference datasets.	Medium	Should	Occupations, cities, country lists
FR-L.5	LOV sets shall be versioned. In-flight assessment sessions shall continue using the LOV version active at session initiation time.	High	Must	Protects in-flight assessments
FR-L.6	Category type (Dominant / Mutual Exclusive) shall be configurable per LOV set. Dominant sets bypass score computation on a positive match.	High	Must	PEP and restricted list behaviour

6.3 FR-P: Risk Parameter Management

Req ID	Requirement	Priority	MoSCoW	Notes
FR-P.1	System shall support creation of risk parameters per tenant, categorised by risk type, flow, category, and sub-category (e.g. Compliance, Credit, PEP, EDD, KYC).	High	Must	From FR-1.1 BRD
FR-P.2	Parameters shall support input types: text, boolean, LOV, and linked LOV (dependent LOV whose options are filtered by the value selected in a parent LOV parameter).	High	Must	From FR-1.2 BRD
FR-P.3	Parameters shall support parent-child hierarchical relationships. Child parameters are rendered only when the parent answer matches the configured trigger value.	High	Must	From FR-1.3 BRD
FR-P.4	Each parameter shall carry: category weight (the % contribution of this question's category to total score), operator, expected value, flag type (PEP / EDD / KYC), filled_by (Customer / System User / Auto-API), is_active, display order, language.	High	Must	From FR-1.4 BRD; category weight on parameter
FR-P.5	Parameter changes shall not affect assessments already in progress. Version isolation must be enforced so in-flight sessions continue with the parameter version active at session start.	High	Must	From FR-1.5 BRD
FR-P.6	All parameter labels and descriptions shall support Arabic and English as minimum language options.	High	Must	SAMA market requirement
FR-P.7	System shall support saving draft assessments for later completion without loss of collected answers.	Medium	Should	From FR-3.5 BRD

Req ID	Requirement	Priority	MoSCoW	Notes
FR-P.8	Administrators shall be able to activate and deactivate parameters without deleting them.	Medium	Should	From FR-1.7 BRD

6.4 FR-S: Scoring Engine

Req ID	Requirement	Priority	MoSCoW	Notes
FR-S.1	Engine shall compute risk score as: Total Score = Sum of (Factor Weight × Category Weight / 100) for all applicable answered, non-EDD-flagged parameters.	High	Must	Core formula
FR-S.2	Engine shall support Dominant category types where a matching LOV answer immediately sets the risk level without executing score computation.	High	Must	PEP + restricted list overrides
FR-S.3	Scoring thresholds (score ranges mapped to Low / Medium / High) shall be configurable per tenant per risk type without requiring code deployment.	High	Must	From FR-2.2, FR-2.5 BRD
FR-S.4	PEP hard override: if a PEP flag is raised at any point during evaluation, risk level is set to PEP immediately. The computed score is irrelevant.	High	Must	From BRD section 5.1
FR-S.5	EDD-flagged answers shall be excluded from the weighted score total. The EDD flag shall be recorded on the assessment session.	High	Must	From FR-2.1 BRD
FR-S.6	For Loan risk type, engine shall support weighted aggregation of Customer and Business risk scores via parent_id and configurable weightage percentages.	High	Must	From FR-2.4 BRD
FR-S.7	Any modification to a previously submitted answer shall trigger an automatic full re-evaluation of the entire assessment. The previous score and risk level must be preserved in answer history before the new result is committed.	High	Must	From BRD re-evaluation rule
FR-S.8	Engine shall produce a score breakdown showing each parameter's individual contribution to the total score.	Low	Could	From FR-2.6 BRD

6.5 FR-A: Answer History & Audit Trail

Req ID	Requirement	Priority	MoSCoW	Notes
FR-A.1	Every submitted answer shall be persisted in the answer history table with: version number, assessment session reference, parameter ID, submitting user ID, answer value, answer type, language code, weight contribution, risk score at time of submission, and risk level at time of submission.	High	Must	From FR-4.1–4.4 BRD
FR-A.2	Answer modification shall create a new version record. The previous version status shall be set to 'superseded'. Existing answer history rows must never be modified in place.	High	Must	From FR-4.2, FR-4.5 BRD
FR-A.3	Each answer change record shall capture: change reason (correction / new information / re-assessment / regulatory request), score delta between old and new weighted contributions, a level_changed flag, and both the previous and new risk levels.	High	Must	From FR-5.1–5.3 BRD
FR-A.4	System shall support a side-by-side diff view comparing any two answer versions for the same parameter within a session.	Medium	Should	From FR-5.4 BRD
FR-A.5	Answer history records shall be retained for a minimum of 7 years from the assessment date.	High	Must	SAMA data retention; FR-5.5 BRD
FR-A.6	All system events, override decisions, admin configuration changes, and assessment actions shall be logged in an immutable, tamper-evident audit trail.	High	Must	CRFR + Saudi Fintech Guidelines
FR-A.7	Audit log entries shall capture: event type, entity type, entity ID, actor (user ID or system), timestamp in UTC, before-state in JSON, after-state in JSON, IP address, and session reference.	High	Must	Forensic readiness requirement

6.6 FR-TP: Third-Party AML & Sanctions Integration

Req ID	Requirement	Priority	MoSCoW	Notes
FR-TP.1	The Risk Assessment Service shall invoke the third-party AML middleware internally as part of the assessment pipeline. LOS/LMS shall not call the third-party service directly.	High	Must	Single orchestration point
FR-TP.2	The service shall submit the required entity data to the third-party middleware for: AML screening, sanctions list checks, local regulatory test checks, and blocklist verification.	High	Must	Full coverage of check types
FR-TP.3	Results received from the third-party middleware shall be stored against the assessment session and returned	High	Must	Unified result payload

Req ID	Requirement	Priority	MoSCoW	Notes
	to LOS/LMS as part of the unified risk assessment response.			
FR-TP.4	Third-party results shall be stored as-is (pass-through). They are not merged into or used to modify the internal weighted risk score.	High	Must	Result independence
FR-TP.5	If the third-party middleware call fails or times out, the service shall handle the failure gracefully — recording the failure status on the session and returning a partial result to LOS/LMS with the failure clearly indicated.	High	Must	Resilience requirement
FR-TP.6	The third-party middleware integration shall be configurable per tenant — allowing different middleware endpoints or credentials to be assigned per tenant if required.	Medium	Should	Multi-tenant flexibility
FR-TP.7	All third-party check invocations and their raw responses shall be logged in the audit trail with timestamp, entity reference, check type, and outcome.	High	Must	Regulatory traceability

7. Non-Functional Requirements

Category	Requirement	Target
Performance	Risk score computation for a standard 20-question assessment shall complete within 3 seconds, excluding any third-party service calls.	P95 < 3 seconds
Availability	The Risk Assessment Service shall maintain 99.9% uptime during business hours.	99.9% SLA
Scalability	Service shall support horizontal scaling to handle peak onboarding volumes without manual infrastructure changes.	Auto-scaling enabled
Security – Rest	All risk data at rest shall be encrypted using AES-256 with tenant-isolated key management.	CRFR + Saudi Fintech Guidelines
Security – Transit	All data in transit shall be encrypted via TLS 1.2 or higher.	CRFR compliance
Tenant Isolation	Strict tenant_id-based data isolation enforced at the application query layer. Zero cross-tenant data visibility at any tier.	Zero-trust model

Category	Requirement	Target
Audit Integrity	Audit log entries shall be stored in an append-only, immutable structure. Modification of existing audit records must be technically prevented.	CRFR framework
Data Retention	Assessment data, answer history, and audit logs shall be retained for a minimum of 7 years.	SAMA compliance
Language	All user-facing content — questions, answer options, validation messages — shall be available in both Arabic and English.	SAMA market requirement
API Standards	The service shall expose RESTful APIs documented to OpenAPI 3.0 standard. All endpoints shall be versioned (e.g. /v1/).	Engineering standard
Observability	Service shall emit structured logs and expose health check endpoints and key operational metrics (latency, error rate, scoring distribution) for platform monitoring.	Operational readiness

8. Acceptance Criteria

The following criteria must be satisfied before the Risk Assessment Service is considered production-ready. Each criterion is directly testable and maps to a functional or non-functional requirement above.

AC ID	Acceptance Criterion	Validation Method
AC-01	A new tenant can be onboarded, LOV sets created, parameters configured, and a complete end-to-end assessment executed — without any engineering intervention.	End-to-end admin UI test
AC-02	PEP dominant override fires immediately when a PEP LOV flag is triggered, setting risk level = PEP and bypassing all score computation.	Unit + integration test
AC-03	Score computation correctly applies the formula (Factor Weight × Category Weight / 100) per answered parameter and produces the correct total.	Scoring unit tests with fixed inputs
AC-04	EDD is triggered when the total score reaches or exceeds the tenant-configured High Risk threshold. EDD answers are stored but excluded from the score total.	Automated test suite
AC-05	The service outbound result payload contains: internal risk score, risk level (Low / Medium / High / PEP), PEP flag, and third-party AML and sanctions check results — all in a single unified response per the defined API contract.	API contract test
AC-06	Modifying a submitted answer creates a new version record, sets the previous version to 'superseded', and triggers a complete re-evaluation of the session.	Integration test with answer change
AC-07	Existing answer history rows cannot be modified. A direct database UPDATE attempt on an answer history row is rejected at the constraint level.	Database constraint test
AC-08	All audit trail entries correctly capture actor identity, timestamp, and before/after state for configuration changes, assessment events, and answer modifications.	Audit log inspection test
AC-09	All API responses return questions and answer options correctly in both Arabic and English based on the 'lang' request parameter.	Bilingual API test
AC-10	A 20-parameter assessment completes scoring within 3 seconds at P95 under simulated concurrent load.	Load test
AC-12	If the third-party AML middleware call fails or times out, the service returns a partial result to LOS/LMS with the internal risk score present and the third-party failure status clearly	Fault injection test

AC ID	Acceptance Criterion	Validation Method
	indicated. The session is not left in an incomplete or hung state.	
AC-11	Two tenants running concurrent assessments see no data from each other at any layer — API response, application logic, or database query.	Tenant isolation test

9. Post-Assessment Status & Approval Workflow

Once the Risk Assessment Service completes an assessment — combining internal risk engine results with third-party AML and sanctions check outcomes — the system must determine the standing of the assessed entity across three distinct status dimensions. This section defines those three status types, how they relate to each other, the configurable scenario rules that drive automated decisions, and the maker-checker approval workflow that governs manual review cases.

9.1 Entity Status Model

Every assessed entity carries three concurrent statuses, each serving a different purpose. Together they give a complete picture of where the entity stands from risk, account lifecycle, and compliance perspectives. All three statuses are driven by the outcome of the risk assessment and are configurable per tenant through the scenario engine.

Important Notice: All statuses lists should be maintained and updated relatively.

Risk Status

The Risk Status is the direct output of the internal scoring engine. It represents the computed risk classification of the entity based on answered parameters, weighted scores, and override rules.

Risk Status	Meaning	Set By	Triggers For Other Statuses
Low	Computed total score falls within the tenant-configured Low risk threshold. Entity presents minimal risk indicators.	System (engine output)	Typically drives Account Status → Active; Compliance Status → Auto Approved.
Medium	Computed total score falls within the Medium risk threshold. Entity presents moderate risk indicators.	System (engine output)	Configurable per tenant — may drive Auto Approved or route to Compliance Pending.

Risk Status	Meaning	Set By	Triggers For Other Statuses
High	Computed total score meets or exceeds the High risk threshold. EDD is triggered.	System (engine output)	Typically drives Account Status → Pending; Compliance Status → Pending (manual review).
PEP	PEP hard override fired — entity is a Politically Exposed Person. Overrides any computed score.	System (engine override)	Drives Account Status → Pending; Compliance Status → Pending. Routed to Compliance Officer.

NOTE: Risk Status is read-only

Risk Status is set exclusively by the scoring engine and cannot be manually overridden. It represents the pure engine output and is the input to the scenario configuration rules that determine Account Status and Compliance Status.

Account Status

The Account Status reflects the entity's lifecycle standing in terms of whether they are permitted to proceed in LOS/LMS. It is determined by the scenario configuration rules applied to the risk assessment outcome.

Account Status	Meaning	Set By	Who Can Change It
Active	Entity has cleared all configured risk checks. LOS/LMS may proceed with onboarding or the relevant process.	System (auto, via scenario rule) or Approver (after manual review)	Compliance Officer or Admin — to Inactive or Blocked only, with mandatory reason.
Inactive	Entity has not yet been assessed, or a previous assessment expired or was invalidated. Awaiting a new or valid assessment before proceeding.	System (auto) or Compliance Officer / Admin	System (on re-assessment) or Compliance Officer.
Pending	Assessment result requires manual review. LOS/LMS processing is on hold until the compliance review is resolved and a final status is set.	System (auto, via scenario rule)	Compliance Officer (Maker) + Approver (Checker) — via maker-checker workflow.
Blocked	Entity is permanently barred from proceeding. Applied when a hard blocking condition is	System (auto, on confirmed blocking scenario) or	Admin only — requires senior approval and documented

Account Status	Meaning	Set By	Who Can Change It
	confirmed — e.g. a confirmed sanctions match or internal blacklist entry.	Compliance Officer / Admin	justification. Logged permanently.

Compliance Status

The Compliance Status captures the review and approval standing of the entity from a compliance team perspective. It tracks whether the entity has been cleared by automated rules, by a human compliance reviewer, or has been rejected or blocked.

Compliance Status	Meaning	Set By	Next Possible Statuses
Auto Approved	All configured scenario rules passed automatically. No manual compliance review was required. Entity is cleared.	System (auto)	Blocked (if new adverse information surfaces post-approval).
Compliance Approved	Entity was in Pending state and has been manually reviewed and approved by a Checker (Approver) through the maker-checker workflow.	Checker (Approver) — via maker-checker workflow	Blocked (by Compliance Officer or Admin with documented reason).
Pending	Entity's assessment triggered a scenario requiring manual review. Awaiting Maker review and Checker approval before a final compliance decision is made.	System (auto, via scenario rule)	Compliance Approved, Rejected, Blocked.
Rejected	Maker submitted a recommendation and Checker rejected the entity — the entity does not meet compliance requirements.	Checker (Approver)	Pending (if re-assessment is initiated by authorised user with new evidence).
Blocked	Entity is permanently blocked at the compliance layer. This is a hard stop — applied on confirmed sanctions matches, confirmed internal blacklist hits, or by a	System (auto on hard blocking scenario) or Senior Compliance Officer / Admin	No further transitions permitted without senior admin intervention and full audit justification.

Compliance Status	Meaning	Set By	Next Possible Statuses
	senior compliance decision.		

HOW THE THREE STATUSES RELATE

Risk Status (engine output) → drives Scenario Configuration rules

Scenario rules → determine Account Status + Compliance Status automatically

Manual review (Pending) → Maker reviews + Checker approves/rejects

Checker decision → updates Account Status and Compliance Status in tandem

Example: Risk Status = PEP → Account Status = Pending + Compliance Status = Pending

Checker approves → Account Status = Active + Compliance Status = Compliance
Approved

Checker rejects → Account Status = Inactive + Compliance Status = Rejected

9.2 Scenario Configuration

Tenant Admins configure scenarios that map specific assessment outcomes — risk status, PEP flag, EDD flag, or third-party check results — to automatic Account Status and Compliance Status decisions. Scenarios are the central control mechanism that allows tenants to define their own risk rules without any code changes.

Each scenario is defined by the following properties:

Property	Required?	Description
Scenario Name	Yes	Descriptive label for this rule (e.g. 'PEP Detected', 'High Risk Score', 'Sanctions Match', 'Local Blacklist Hit', 'AML Inconclusive').
Trigger — Risk Status	Cond.	Internal risk level that activates this scenario: Low, Medium, High, or PEP. At least one trigger condition (risk status, PEP flag, third-party result) must be set.
Trigger — PEP Flag	Cond.	true / false. If set to true, this scenario fires whenever the PEP override is detected regardless of score.
Trigger — 3rd Party	Cond.	Third-party check type (AML / Sanctions / Local Test / Blocklist) and result (match / no match / inconclusive). Fires when the specified check returns the specified result.

Property	Required?	Description
Resulting Account Status	Yes	The Account Status the system assigns when this scenario triggers: Active, Inactive, Pending, or Blocked.
Resulting Compliance Status	Yes	The Compliance Status the system assigns: Auto Approved, Pending, or Blocked. Compliance Approved and Rejected are set only via maker-checker workflow.
Requires Manual Review	Yes	Boolean. If true, Compliance Status is set to Pending and a review task is created and routed. If false, statuses are applied immediately by the system.
Notify Role	Cond.	Role(s) to notify when a review task is created: Compliance Officer, Risk Manager, Relationship Manager. Required when Requires Manual Review = true.
Is Active	Yes	Boolean. Inactive scenarios are skipped during evaluation. Allows tenants to enable or disable rules without deletion.

EXAMPLE SCENARIOS (Illustrative — tenant-configured)

Name: 'PEP Detected' | Trigger: PEP Flag = true | Acct: Pending | Compliance: Pending | Review: Yes | Notify: Compliance Officer
 Name: 'High Risk Score' | Trigger: Risk Status = High | Acct: Pending | Compliance: Pending | Review: Yes | Notify: Risk Manager
 Name: 'Medium Risk' | Trigger: Risk Status = Medium | Acct: Active | Compliance: Auto Approved | Review: No
 Name: 'Low Risk' | Trigger: Risk Status = Low | Acct: Active | Compliance: Auto Approved | Review: No
 Name: 'Sanctions Match' | Trigger: Sanctions check = match | Acct: Blocked | Compliance: Blocked | Review: No
 Name: 'Local Blacklist Hit' | Trigger: Local Test = match | Acct: Blocked | Compliance: Blocked | Review: No
 Name: 'AML Inconclusive' | Trigger: AML check = inconclusive | Acct: Pending | Compliance: Pending | Review: Yes | Notify: Compliance Officer
 Name: 'International Hit' | Trigger: International Sanctions = match | Acct: Blocked | Compliance: Blocked | Review: No

All values above are illustrative. Each tenant configures its own scenarios via the admin portal.

9.3 System Auto-Decision Rules

After the assessment completes, the system evaluates all active scenarios for the tenant. Multiple scenarios may match simultaneously. The system applies the most restrictive outcome and records all matched scenarios in the audit trail. These rules should be configurable.

Step	System Action	Account Status Outcome	Compliance Status Outcome
1 – Evaluate	Evaluate all active, ordered scenarios against the assessment result (Risk Status, flags, third-party results).	—	—
2 – Hard Blocks	Check for any triggered scenarios with Resulting Account Status = Blocked (e.g. confirmed sanctions or local blacklist match). Apply immediately — no approval possible.	Blocked	Blocked
3 – PEP Override	If PEP flag is true and a PEP scenario is active: apply Pending statuses and create a Compliance Officer review task.	Pending	Pending
4 – High Risk	If Risk Status = High and a High Risk scenario is active: apply Pending statuses and create a Risk Manager review task.	Pending	Pending
5 – Inconclusive	If any third-party check returns inconclusive and a matching scenario is active: apply Pending statuses and create a Compliance Officer review task.	Pending	Pending
6 – Medium Risk	If Risk Status = Medium and a Medium scenario is configured as auto-approve: apply statuses immediately. No review task created.	Active (configurable)	Auto Approved
7 – All Clear	If Risk Status = Low and all third-party checks = no match: apply Active and Auto Approved immediately.	Active	Auto Approved
8 – No Match	If no configured scenario matches: apply the tenant-configured default statuses. Record in audit trail that no scenario was matched.	Tenant default	Tenant default

PRIORITY & CONFLICT RESOLUTION

When multiple scenarios match, the system applies the most restrictive status combination:

Account Status: Blocked > Pending > Inactive > Active

Compliance Status: Blocked > Pending > Auto Approved

All matched scenarios are recorded in the audit trail — not only the one whose status is applied. Tenant Admins assign a numeric priority to each scenario to control evaluation order within the same severity level.

9.4 Manual Review & Maker-Checker Approver

When a Pending outcome is triggered, the system creates a review task and routes it to the configured role. The review follows a two-stage Maker-Approver pattern — the Maker prepares and recommends, and the Approver makes the binding final decision. No single user may act as both Maker and Approver on the same record.

Roles

Role	Who Holds It	Responsibility	Constraints
Maker	Compliance Officer (for PEP / EDD / AML / sanctions tasks)Risk Manager (for High Risk score tasks)Configurable per scenario	Opens the review task. Reviews the full assessment result — risk score, risk status, all flags, third-party outcomes — against the triggered scenario and entity profile. Adds a mandatory written review note. Submits a formal recommendation to the Approver: Recommend Approve or Recommend Reject.	Cannot act as Approver on the same record. Cannot close or approve their own submission. If the Maker is also the entity's onboarding officer or relationship manager they must be recused.
Approver	Senior Compliance Officer (for PEP / AML / sanctions tasks)Head of Risk / Senior Risk Manager (for High Risk tasks)Configurable per scenario	Receives the Maker's recommendation and reviews all underlying assessment data independently. Makes the binding final decision: Approve, Reject, or Return to Maker for further work. Must document their decision with a mandatory approval note.	Must be a different user from the Maker on the same record. Must hold the Approver role for the relevant risk domain. Cannot delegate the decision to another user once the task is in their queue.
System	Automated service	Creates and routes review tasks to the correct role queue based on the triggered scenario configuration. Enforces the Maker-Approver rule at submission time. Applies the final Account Status and Compliance Status once the Approver acts. Logs all events to the immutable audit trail.	Cannot override an Approver decision. Cannot close or resolve a Pending task without a valid Approver action. Cannot assign the same user as both Maker and Approver.

Approval Flow

Step	Actor	Action	Account Status	Compliance Status
1	System	Assessment completes. Scenario evaluation finds a Pending-triggering match. System creates a review task and routes it to the Maker queue for the configured role.	Pending	Pending
2	Maker	Receives task notification. Opens the review task. Reviews the full assessment — internal risk score, risk status, PEP / EDD flags, all third-party AML and sanctions outcomes, triggered scenario details, and entity profile.	Pending	Pending
3	Maker	Adds a mandatory written review note documenting observations and rationale.	Pending	Pending
4	Maker	Submits recommendation to the Approver:– Recommend Approve: entity is acceptable; no adverse findings warrant blocking.– Recommend Reject: entity should not proceed; adverse findings are substantiated.	Pending	Pending
5	System	Locks the record from further Maker edits. Routes the task to the Approver queue. Validates that the Approver is a different user from the Maker — blocks and alerts if the same user attempts to approve.	Pending	Pending
6	Approver	Receives task notification. Opens the task. Reviews the Maker's recommendation, review note, and all underlying assessment data independently.	Pending	Pending
7a	Approver	Approves: confirms the entity is acceptable and meets compliance requirements. Adds mandatory approval note.	Active	Compliance Approved
7b	Approver	Rejects: confirms the entity does not meet requirements and should not proceed. Adds mandatory rejection note.	Inactive	Rejected
7c	Approver	Returns to Maker: the submission requires additional information or further investigation before a decision can be made. Adds a note specifying exactly what is needed.	Pending	Pending
8	Maker	If returned (Step 7c): addresses the Approver's requirements, updates the review note, and resubmits. The task re-enters the Approver queue at Step 5.	Pending	Pending

Step	Actor	Action	Account Status	Compliance Status
9	System	All steps — task creation, Maker review and submission, Approver decision, any returns and resubmissions — logged to the immutable audit trail with actor identity, role, timestamp, action type, and note text.	Final state	Final state

Timing & Escalation

- Each review task carries a configurable SLA duration set per scenario type by the Tenant Admin — for example: 48 hours for High Risk score tasks, 24 hours for PEP tasks, 12 hours for inconclusive international sanctions checks. SLA durations apply independently to the Maker stage and the Approver stage.
- If the Maker does not submit within the SLA, the system auto-escalates the task to the configured escalation role and records the escalation in the audit trail.
- If the Approver does not act within their SLA stage, the system auto-escalates to the next-level role (e.g. Head of Compliance, Chief Risk Officer) and records the escalation.
- Makers and Approvers receive configurable notifications — in-app and email — at task assignment, SLA warning threshold, escalation trigger, and final decision confirmation.

9.5 Status Transition Reference

The tables below summarise all valid transitions for Account Status and Compliance Status. Any transition not listed is not permitted by the system. Both statuses are updated together when an Approver decision is made.

Account Status Transitions

From	To	Trigger	Actor	Conditions
—	Active	All Clear scenario — Low risk, all 3rd-party checks clear.	System (auto)	No blocking or pending scenario triggered.
—	Active	Medium risk scenario configured as auto-approve.	System (auto)	Tenant scenario: Medium → Active, no review required.
—	Pending	High Risk, PEP, or inconclusive 3rd-party scenario triggered.	System (auto)	Requires Manual Review = true on the triggered scenario.
—	Inactive	Assessment invalid or not yet run (initial state).	System (auto)	Default pre-assessment state.

From	To	Trigger	Actor	Conditions
—	Blocked	Hard blocking scenario triggered (sanctions match, local blacklist).	System (auto)	Requires Manual Review = false. No approval route.
Pending	Active	Approver approves Maker's recommendation.	Approver	Maker submission present. Approver 2260 Maker.
Pending	Inactive	Approver rejects Maker's recommendation.	Approver	Maker submission present. Approver 2260 Maker.
Pending	Pending	Approver returns task to Maker for further review.	Approver	Mandatory Approver note required.
Active	Blocked	New adverse information confirmed post-approval.	Compliance Officer / Admin	Mandatory reason note. Senior sign-off required. Logged permanently.
Inactive	Pending	Re-assessment initiated or appeal submitted.	Compliance Officer / Admin	New assessment must be completed before Pending can move to Active.

Compliance Status Transitions

From	To	Trigger	Actor	Conditions
—	Auto Approved	All Clear scenario — no manual review required.	System (auto)	No review scenario triggered.
—	Pending	Review scenario triggered (PEP, High Risk, inconclusive).	System (auto)	Requires Manual Review = true.
—	Blocked	Hard blocking scenario triggered.	System (auto)	Requires Manual Review = false.
Pending	Compliance Approved	Approver approves.	Approver	Maker submission present. Approver 2260 Maker.
Pending	Rejected	Approver rejects.	Approver	Maker submission present. Approver 2260 Maker.
Pending	Pending	Approver returns to Maker.	Approver	Mandatory Approver note required.
Rejected	Pending	Re-assessment initiated with new evidence.	Compliance Officer / Admin	New full assessment must be run first.

From	To	Trigger	Actor	Conditions
Compliance Approved	Blocked	Post-approval adverse finding confirmed.	Senior Compliance / Admin	Mandatory documented justification. Logged permanently.
Auto Approved	Blocked	Post-approval adverse finding confirmed.	Senior Compliance / Admin	Mandatory documented justification. Logged permanently.

MAKER-CHECKER ENFORCEMENT

The system must technically enforce that the Maker and Approver are never the same user. This applies to all Pending → Active / Inactive / Compliance Approved / Rejected transitions. An Approver who is also the entity's onboarding officer or relationship manager must be recused — a different qualified Approver must be assigned. All recusals, reassignments, returns, and escalations are logged in the audit trail.

END OF DOCUMENT – CONFIDENTIAL | FV-HLD-RISK-002 v1.0